

ResolvX

Asset Management Policy

Topic-Specific Policy - Asset Inventory, Ownership & Lifecycle

POL-011 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-011
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A5.9, A5.10, A5.11, A7.9, A8.19 · NIST CSF 2.0 ID.AM-01/02/05 · SOC 2 CC6.1

1. Purpose

This Asset Management Policy establishes how ResolvX identifies, records, assigns ownership to, and manages the lifecycle of the technology and information assets it depends on.

A current, accurate asset register is the foundation the rest of ResolvX's security programme is built on logging (POL-007), backup and recovery (POL-009), and access control (POL-003) all assume a defined, known set of assets to protect. This policy formalises ResolvX's asset inventory as a maintained, version-controlled register with a named owner and a defined review cycle, consistent with ISO 27001:2022 A5.9.

2. Scope

This policy applies to all assets that store, process, or transmit ResolvX or client data, or that ResolvX otherwise relies on to operate:

- Cloud infrastructure assets (AWS accounts, VPCs, compute, storage, databases).
- Corporate IT assets (laptops, software licenses, SaaS platforms).
- Information assets (as classified under POL-004).
- Source code repositories and infrastructure-as-code.

3. Asset Categories

Category	Examples	Register Owner
Cloud infrastructure	AWS VPC, EC2, EKS, RDS, S3, IAM, Secrets Manager	Head of Cloud Ops
Corporate IT & SaaS	Laptops (Jamf), Microsoft 365, Slack, Notion, 1Password	IT Admin
Source code & CI/CD	GitHub repositories, pipelines, infrastructure-as-code	DevSecOps
Information assets	Data classified under POL-004, regardless of storage location	Individual Information Owners (per POL-004 §4)

4. Asset Register

Every in-scope asset is recorded in the asset register with, at minimum, the following fields:

Field	Purpose
Asset ID	Unique identifier for cross-referencing across registers and audit evidence
Name / Description	What the asset is
Category	Per §3
Owner	Named individual or role accountable for the asset. Never left blank or assigned to a team alias

Field	Purpose
Criticality	Critical / High / Medium / Low, consistent with the tiers used in POL-008's Business Impact Analysis
Data Classification	Where applicable, per POL-004
Environment	Production / Staging / Development / Corporate
Lifecycle Status	Active / Decommissioning / Decommissioned
Last Reviewed	Date of the most recent reconciliation (§7)

The asset register itself is a Restricted-tier document under POL-004, since it maps directly to ResolvX's attack surface.

5. Asset Ownership & Lifecycle

5.1 Ownership

Every asset has exactly one named owner accountable for its accuracy in the register, its appropriate classification, and its eventual decommissioning. Ownership transfers explicitly when responsibility changes, else an asset is never left ownerless because someone changed roles.

5.2 Acquisition

New cloud infrastructure, corporate software, or SaaS platforms are added to the register at the time of provisioning, not retroactively discovered. Provisioning a new AWS resource or corporate SaaS subscription is the trigger for a register entry, not a follow-up task.

5.3 Decommissioning

When an asset reaches end of use, the owner completes the following before it is marked Decommissioned:

- Data on the asset is handled per its classification (secure deletion for Restricted/Confidential data)
- Any access, credentials, or integrations tied to the asset are revoked
- Software licenses are reclaimed or cancelled, not left running unused
- The register entry is updated to Decommissioned with a date, rather than deleted. Decommissioned assets remain visible in the register for audit history

6. Software Asset Management

Only software on the Authorized Software List (a companion register to this policy) may be installed on corporate endpoints or deployed to production infrastructure, consistent with ISO A8.19 and the acceptable use expectations set in POL-002.

- IT Admin maintains the Authorized Software List for corporate endpoints, enforced through Jamf.
- DevSecOps maintains the equivalent standard for production dependencies, enforced through Snyk's dependency scanning and code review.
- A request to add new software to the Authorized Software List is reviewed against licensing terms, vendor security posture (per POL-005 if the vendor will access ResolvX data), and business justification before approval.

7. Discovery, Reconciliation & Unauthorized Assets

7.1 Reconciliation Cadence

A register that is only accurate on the day it was written is not a control. The register is reconciled quarterly against authoritative sources rather than maintained by memory:

Source of Truth	Reconciled Against	Owner
AWS resource inventory (AWS Config / tagging)	Cloud infrastructure register entries	Head of Cloud Ops
Jamf device inventory	Corporate IT asset register entries	IT Admin
GitHub organization audit (repos, members)	Source code & CI/CD register entries	DevSecOps
SaaS admin consoles (M365, Slack, Notion, 1Password)	Corporate IT asset register entries	IT Admin

7.2 Unauthorized (Shadow) Assets

An AWS resource without required tags, or a SaaS subscription discovered outside the procurement process, is treated as an unauthorized asset until it is either brought into the register with a named owner or decommissioned. Repeated unauthorized provisioning by the same team is escalated to VP Engineering.

7.3 Continuous Detection

Quarterly reconciliation alone allows up to three months of unmanaged exposure before an unauthorized asset is caught. Two lighter-weight, continuous checks close that gap between reconciliation cycles:

- AWS Cost Anomaly Detection and budget alerts notify Head of Cloud Ops of new spend against untagged or unrecognized resources as it occurs, not at quarter-end.
- Okta's application catalogue is reviewed monthly by IT Admin for new SaaS sign-ins authenticated through corporate SSO, surfacing shadow SaaS adoption closer to when it happens.

Neither check replaces the quarterly reconciliation in §7.1 as they narrow the window an unauthorized asset can go unnoticed, rather than serving as a complete inventory method on their own.

8. Asset Return

Corporate assets (laptops, access badges, credentials) issued to personnel are returned or revoked as part of the offboarding process, coordinated between IT Admin and HR. A departing employee's assets are reflected in the register within 5 business days of their last working day and not left as an open item indefinitely.

9. Roles & Responsibilities

9.1 GRC Lead

- Owns this policy and the consolidated asset register.
- Confirms the quarterly reconciliation (§7.1) has occurred across all four sources.
- Logs any unresolved unauthorized asset as a Corrective Action Plan item.

9.2 Head of Cloud Ops

- Maintains cloud infrastructure register entries and their criticality/environment fields.

9.3 IT Admin

- Maintains corporate IT and SaaS register entries and the Authorized Software List.
- Executes asset return and revocation during offboarding (§8).

9.4 DevSecOps

- Maintains source code and CI/CD register entries and the production software standard (§6).

10. Compliance and Enforcement

An asset discovered without a register entry or a named owner during reconciliation, or software installed outside the Authorized Software List without approval, is treated as a control deficiency and logged in the Corrective Action Plan.

Where an unauthorized asset resulted from an individual knowingly bypassing procurement or provisioning controls, rather than a process gap or genuine oversight, it is additionally addressed as a policy violation under POL-002's disciplinary process, up to and including suspension of system access or termination, proportionate to whether the action was deliberate, its impact, and whether it was repeated after an earlier escalation under §7.2.

11. Document Control

Policy ID	POL-011
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A5.9, A5.10, A5.11, A7.9, A8.19 · NIST CSF 2.0 ID.AM-01, ID.AM-02, ID.AM-05 · SOC 2 TSC CC6.1
Related Documents	POL-001 (Information Security Policy), POL-002 (Acceptable Use Policy), POL-004 (Data Classification Policy), POL-005 (Vendor Management Policy), Authorized Software List (evidence artifact)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		